COMPTIA SECURITY+ SY0-701 DOMÍNIO 1 · CONCEITOS GERAIS DE SEGURANÇA (12%)

Security+ 1.1 · Security Controls

Mestre CyberSec · **Aula 1.1 — Security Controls** (11:48) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Controle = qualquer medida que evita, avisa, conserta ou compensa. 4 CATEGORIAS (by means): Technical (ferramenta), Managerial (documento/política), Operational (pessoas no dia-a-dia), Physical (barreira física). 6 TIPOS (by purpose): Preventive (barra antes), Deterrent (desanima

💡 Highlights que a prova CompTIA cobra

- Matriz 4×6 = a tabela mental da aula
- Preventive barra ANTES — Detective AVISA — Corrective CONCERTA
- Compensating: usa MEIOS DIFERENTES quando o ideal não dá — temporário
- Directive = o mais fraco: 'authorized personnel only' não barra ninguém
- Antivírus: technical + preventive e detective dependendo do modo
- Extintor de incêndio = corrective — repara durante, NÃO previne

🎯 Dicas de Prova & Cenários Típicos da Banca

- Gatilhos: 'after the event'→corrective · 'discourage'→deterrent · 'identifies/logs'→detective · 'alternative approach'→compensating
- A pergunta do Messer: 'what CATEGORY does it fit in (technical/managerial/operational/physical) AND what TYPE?'

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 1.1 — Security Controls)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Categorias de Controle

Os quatro grupos que descrevem COMO um controle é implementado (seu meio): Técnico (ferramentas de tecnologia), Gerencial (políticas, procedimentos e processos), Operacional (pessoas nas atividades do dia a dia) e Físico (barreiras do mundo real).

⚠️ ***Armadilha CompTIA:*** *Pergunta-padrão da prova: 'qual a categoria?'. Antivírus/firewall/criptografia/ACL = Technical; política AUP/avaliação de risco = Managerial; treinamento, resposta a incidentes e guarda executando a função = Operational; cerca, tranca, câmera = Physical. Cruze cada categoria com um tipo para montar a matriz 4×6 mental da aula.*

• Tipos de Controle

Os seis grupos que descrevem POR QUE um controle existe (sua finalidade): Preventivo, Dissuasivo, Detetivo, Corretivo, Compensatório e Diretivo.

⚠️ ***Armadilha CompTIA:*** *Gatilho na questão: 'purpose/goal' = Tipo; 'means/how implemented' = Categoria. Resumo de 6 palavras: Preventive BARRA antes; Detective AVISA; Corrective CONCERTA; Deterrent DESANIMA; Compensating USA MEIO DIFERENTE; Directive apenas ORIENTA (o mais fraco).*

• Controle Preventivo

Controle que barra um incidente ANTES que ele aconteça, negando a atividade indesejada de antemão (ex.: regras de firewall, listas de controle de acesso, crachá de acesso).

⚠️ ***Armadilha CompTIA:*** *Palavra-chave na prova: 'block/deny'. Firewall e ACL = technical + preventive. Cuidado com o antivírus: só é preventive em modo de bloqueio em tempo real; em modo de varredura/detecção ele vira detective.*

• Controle Detetivo

Controle que identifica e registra um incidente durante ou depois que ele acontece, avisando que houve violação (ex.: revisão de logs, monitoramento, sistema de alarme).

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'identifies/alerts/records' — detecta e avisa, mas NÃO impede nada. Logs e monitoramento contínuo = detective. Câmera gravando = physical + detective; a mesma câmera visível com placa de aviso atua como deterrent.*

• Controle Corretivo

Controle que repara, conserta ou restaura um sistema durante ou depois de um incidente, para reduzir o impacto (ex.: extintor de incêndio, restauração de backup, site de contingência).

⚠️ ***Armadilha CompTIA:*** *Clássico pegadinha da prova: EXTINTOR = corrective, pois conserta DURANTE o incêndio — não é preventive. Backup restaurado após falha/ataque = corrective. Palavras-chave: 'fix', 'restore', 'reduce impact', 'repair'.*

• Controle Dissuasivo

Controle que desanima o atacante de sequer tentar uma violação, sem bloquear ativamente a ação (ex.: placas de aviso, iluminação ativada por movimento, guarda visível).

⚠️ ***Armadilha CompTIA:*** *Distinção-chave: deterrent DESANIMA mas não barra (preventive BARRA de verdade). Placa 'monitorado por câmeras' = deterrent. Não confunda com directive: a placa deterrent implica consequência/punição; a directive apenas orienta.*

• Controle Compensatório

Controle alternativo usado quando o controle ideal não pode ser implementado, proporcionando proteção semelhante por meios diferentes, geralmente de forma temporária.

⚠️ ***Armadilha CompTIA:*** *Gatilho na prova: 'when the ideal/required control cannot be used', 'alternative measure', 'similar protection using a different means'. Ex.: sistema legado sem atualização disponível → segmentação e monitoração intensiva como compensating (solução de ponte, não definitiva).*

• Controle Diretivo

Controle que guia ou direciona o comportamento por meio de procedimentos, placas ou políticas, sem reforçar tecnicamente o cumprimento (ex.: placa 'somente pessoal autorizado').

⚠️ ***Armadilha CompTIA:*** *O MAIS FRACO dos 6 tipos: não barra, não desanima com punição, não detecta — apenas orienta. 'Authorized personnel only' não impedirá ninguém tecnicamente. Se na questão algo é efetivamente enforced (aplicado), NÃO é directive.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Categorias de Controles: Técnico, Gerencial, Operacional e Físico

🏠 **Analogia Intuitiva:** Pense na proteção de uma agência bancária de alto valor. O controle Gerencial (Managerial) é o código de conduta e as políticas corporativas assinadas pela diretoria; o Físico (Physical) são os muros altos, portas giratórias blindadas e cercas perimetrais; o Técnico (Technical) são os sensores a laser, cofres com trancas digitais biométricas e criptografia dos dados; e o Operacional (Operational) são os procedimentos diários executados pelas pessoas, como vigilantes conferindo crachás e caixas trancando gavetas ao sair da mesa.

🔍 **Causa Raiz / Por que foi criado:** Nenhum controle isolado é suficiente. Se uma organização investir milhões em firewalls de última geração (técnico), mas não houver treinamento de colaboradores (operacional) ou políticas formais com punições aprovadas pela diretoria (gerencial), um invasor conseguirá acesso facilmente explorando o fator humano.

🛡️ **Visão do Auditor de GRC:** O auditor de GRC cataloga cada controle em frameworks como NIST SP 800-53 ou ISO/IEC 27001. Fiscaliza evidências formais: políticas assinadas pelo C-Level (gerencial), logs de configuração de firewalls e regras IAM (técnico), atas e listas de presença de treinamentos anti-phishing (operacional), e relatórios de inspeção física predial com vistorias de portas e cercas (físico).

⚠️ **Como cai na Prova CompTIA:** A prova pergunta: 'Qual a CATEGORIA do controle?' Dica infalível: Software, hardware, criptografia ou regras de switch = Technical. Políticas escritas, análise de impacto e avaliações de risco = Managerial. Ações humanas diárias, conscientização e background checks = Operational. Muros, portarias, fechaduras e iluminação = Physical.

📌 Tipos Funcionais: Preventivo (Preventive) vs. Dissuasivo (Deterrent) vs. Diretivo (Directive)

🏠 **Analogia Intuitiva:** Um portão de ferro trancado com leitor biométrico é Preventivo (ele bloqueia fisicamente a passagem de quem não tem autorização). Uma placa grande com o aviso 'Atenção: Área Monitorada por Câmeras e Cães de Guarda' é Dissuasivo (não barra fisicamente, mas desmotiva psicologicamente o invasor pelo medo de ser pego). Já uma placa na recepção dizendo 'Proibido Fumar / Permitido Apenas Pessoal Autorizado' ou o regulamento interno da empresa é Diretivo (indica a conduta correta esperada, dependendo da conformidade voluntária das pessoas).

🔍 **Causa Raiz / Por que foi criado:** Para proteger ativos com eficiência e economia, a segurança deve operar em camadas: primeiro desestimulando a tentativa de invasão (dissuasivo e diretivo) para reduzir o volume de ataques, e em seguida bloqueando categoricamente qualquer tentativa que ainda assim aconteça (preventivo).

🛡️ **Visão do Auditor de GRC:** O auditor realiza testes de eficácia de controle: testa se os controles preventivos realmente rejeitam acessos não autorizados (ex: simulação de invasão física ou portas bloqueadas em firewalls) e confere se políticas e sinalizações mandatórias estão visíveis, atualizadas e homologadas pelo setor jurídico da empresa.

⚠️ **Como cai na Prova CompTIA:** Gatilhos da banca: 'Discourages / warns away an attacker' -> Deterrent. 'Stops / blocks prior to execution' (ex: IPS, firewall, mantrap, bloqueio de conta após tentativas inválidas) -> Preventive. 'Specifies acceptable behavior / mandatory policy rules' -> Directive.

📌 Tipos Funcionais: Detectivo (Detective) vs. Corretivo (Corrective)

🏠 **Analogia Intuitiva:** O sensor de fumaça disparando a sirene no teto é Detectivo (ele avisa imediatamente que há fumaça, registra o alarme no painel, mas não apaga um centímetro de fogo). O extintor de incêndio na parede, o sprinkler automático que espalha água e a restauração de um backup de dados após um desastre são Corretivos (entram em ação para combater o sinistro em andamento e restaurar a normalidade).

🔍 **Causa Raiz / Por que foi criado:** Nenhum sistema preventivo é 100% infalível; invasores e falhas operacionais eventualmente ultrapassam a barreira inicial. Sem controles detectivos, a empresa demora meses para saber que foi violada; sem controles corretivos, ela não sobrevive aos prejuízos do desastre.

🛡️ **Visão do Auditor de GRC:** O auditor analisa planos de Continuidade de Negócios (BCP) e Resposta a Incidentes (IRP): inspeciona alertas de SIEM e logs de IDS para avaliar o Mean Time to Detect (MTTD - Detectivo) e revisa testes periódicos de restauração de backup e failover para avaliar o Mean Time to Recover (MTTR - Corretivo).

⚠️ **Como cai na Prova CompTIA:** Pegadinha clássica da CompTIA: Extintor de incêndio NÃO é preventivo; ele é CORRETIVO (pois só atua durante ou após o início do sinistro). Câmera de CFTV gravando o estacionamento é DETECTIVA (fornece gravação para investigação). IDS é Detectivo; IPS é Preventivo.

📌 Controles Compensatórios (Compensating Controls)

🏠 **Analogia Intuitiva:** Imagine um elevador de carga industrial que quebrou e a peça de reposição vai demorar 15 dias para chegar da fábrica. Para não paralisar o estoque e impedir que os funcionários carreguem caixas pesadas por escadas íngremes arriscando quedas, a gerência aluga temporariamente uma esteira rolante externa motorizada e escala dois supervisores dedicados para acompanhar todo o trajeto.

🔍 **Causa Raiz / Por que foi criado:** Muitas vezes uma organização utiliza sistemas legados essenciais (ex: equipamentos médicos hospitalares ou controladores industriais SCADA) que tecnicamente não suportam controles modernos obrigatórios (como autenticação multifator ou criptografia forte), exigindo uma salvaguarda substituta que mitigue o risco de maneira equivalente.

🛡️ **Visão do Auditor de GRC:** Em frameworks rigorosos como PCI-DSS, o auditor exige a Planilha de Controle Compensatório (CCW): documento formal comprovando a inviabilidade técnica do controle primário, a comprovação de que o controle substituto alcança nível equivalente de segurança (ex: isolamento em VLAN dedicada com firewall e monitoramento estrito) e aprovação formal do comitê de riscos.

⚠️ **Como cai na Prova CompTIA:** Palavras-chave no cenário: 'Legacy system cannot support the primary requirement / Alternative safeguard deployed to satisfy security intent / Temporary mitigating measure'. A resposta é sempre Compensating Control.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Câmera de segurança visível com placa de alerta no portão	**Controle Dissuasivo (Deterrent Control)**
Catraca com leitor biométrico que tranca e barra acesso não autorizado	**Controle Preventivo e Físico (Preventive & Physical)**
Uso de extintor de incêndio ou restauração de backup após incidente	**Controle Corretivo (Corrective Control)**
Auditoria de logs e alertas gerados por sistema SIEM ou IDS	**Controle Detectivo e Técnico (Detective & Technical)**
VLAN isolada com monitoramento estrito para servidor legado que não suporta patch	**Controle Compensatório (Compensating Control)**
Política de Segurança da Informação (AUP) assinada formalmente por todos os empregados	**Controle Gerencial e Diretivo (Managerial & Directive)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um engenheiro de rede configura o firewall de perímetro para negar TCP 445 de entrada vindo da internet após uma avaliação de vulnerabilidades. Qual das opções a seguir MELHOR descreve esse controle?

A) Técnico preventivo

B) Físico dissuasivo

C) Gerencial corretivo

D) Operacional detectivo

QUESTÃO 2 · CENÁRIO DE EXAME

O CISO atualiza a política de uso aceitável da organização para exigir que todos os funcionários relatem e-mails de phishing suspeitos à equipe de segurança em até 15 minutos. Qual das op��ões a seguir MELHOR descreve esse controle?

A) Técnico preventivo

B) Gerencial diretivo

C) Operacional detectivo

D) Físico compensatório

QUESTÃO 3 · CENÁRIO DE EXAME

A equipe de segurança implanta uma regra de SIEM que correlaciona falhas de login VPN e envia um alerta quando 10 falhas ocorrem do mesmo endereço IP em 5 minutos. Qual das opções a seguir MELHOR descreve esse controle?

A) Físico preventivo

B) Gerencial dissuasivo

C) Técnico detectivo

D) Operacional corretivo

QUESTÃO 4 · CENÁRIO DE EXAME

Após um incidente de ransomware, a equipe restaura os servidores afetados a partir de backups imutáveis e reconstrói o controlador de domínio. Qual das opções a seguir MELHOR descreve esse controle?

A) Detectivo

B) Preventivo

C) Dissuasivo

D) Corretivo

QUESTÃO 5 · CENÁRIO DE EXAME

Um data center coloca placas de aviso bem visíveis com os dizeres 'Somente Pessoal Autorizado' e instala câmeras com luzes piscantes nas entradas para desencorajar invasores. Qual das opções a seguir MELHOR descreve esse controle?

A) Preventivo

B) Dissuasivo

C) Detectivo

D) Compensatório

QUESTÃO 6 · CENÁRIO DE EXAME

Uma empresa não consegue atualizar um dispositivo médico legado para suportar autenticação multifator. Para reduzir o risco, a segurança coloca o dispositivo em uma VLAN isolada, restringe o acesso a um jump host e monitora todas as sessões. Qual das opções a seguir MELHOR descreve esse controle?

A) Compensatório

B) Diretivo

C) Corretivo

D) Detectivo

QUESTÃO 7 · CENÁRIO DE EXAME

Uma instalação governamental instala um mantrap com duas portas interligadas e um leitor de crachá na entrada da sala de servidores. Qual das opções a seguir MELHOR descreve esse controle?

A) Operacional dissuasivo

B) Técnico detectivo

C) Gerencial compensatório

D) Físico preventivo

QUESTÃO 8 · CENÁRIO DE EXAME

O departamento de segurança realiza treinamento trimestral de simulação de phishing para toda a equipe e exercícios de mesa de resposta a incidentes com líderes de departamento. Qual das seguintes categorias de controle MELHOR descreve essas atividades?

A) Técnico

B) Gerencial

C) Operacional

D) Físico

QUESTÃO 9 · CENÁRIO DE EXAME

Um hospital afixa uma política em cada ala declarando que os dados de pacientes só devem ser acessados em dispositivos aprovados e apenas quando clinicamente necessário; a equipe deve reconhecê-la anualmente. Qual dos seguintes tipos de controle MELHOR descreve esse controle?

A) Diretivo

B) Preventivo

C) Detectivo

D) Corretivo

QUESTÃO 10 · CENÁRIO DE EXAME

Um data center instala sensores de movimento infravermelho e contatos de porta que disparam um alarme quando movimento é detectado fora do horário comercial. Qual das opções a seguir MELHOR descreve esse controle?

A) Físico preventivo

B) Físico detectivo

C) Operacional dissuasivo

D) Técnico corretivo

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — Técnico preventivo

Um firewall é um controle técnico porque é implementado por meio de tecnologia. Negar tráfego SMB de entrada (TCP 445) bloqueia a atividade antes que ela alcance sistemas internos, tornando-o preventivo.

Questão 2: Alternativa B — Gerencial diretivo

A política de uso aceitável é um controle gerencial porque é um documento formal que rege o comportamento. Ela orienta os funcionários a executar uma ação específica, portanto também é diretiva.

Questão 3: Alternativa C — Técnico detectivo

Uma regra de correlação de SIEM é um controle técnico porque usa uma ferramenta de segurança. Ela identifica atividade de autenticação suspeita e alerta analistas, portanto é detectiva.

Questão 4: Alternativa D — Corretivo

Restaurar a partir de backups e reconstruir sistemas ocorre após um incidente para retornar as operações ao normal. Isso torna o controle corretivo.

Questão 5: Alternativa B — Dissuasivo

Placas de aviso e câmeras visíveis desencorajam indivíduos de tentar acesso não autorizado. O propósito principal é dissuadir, portanto este é um controle dissuasivo.

Questão 6: Alternativa A — Compensatório

Como o controle preferido (MFA) não pode ser implementado no dispositivo legado, a organização usa isolamento, jump host e monitoramento como medida alternativa de redução de risco. Este é um controle compensatório.

Questão 7: Alternativa D — Físico preventivo

Um mantrap, portas interligadas e leitor de crachá são barreiras físicas que impedem a entrada não autorizada antes que o acesso seja concedido. Este é um controle físico preventivo.

Questão 8: Alternativa C — Operacional

Treinamento de conscientização e exercícios de mesa são atividades diárias conduzidas por pessoas, o que as torna controles operacionais. Elas não dependem primariamente de tecnologia, documentos formais de política isoladamente ou barreiras físicas.

Questão 9: Alternativa A — Diretivo

A política instrui a equipe sobre o comportamento exigido e as condições de acesso. Como seu propósito principal é direcionar ações em vez de impô-las tecnicamente ou monitorá-las, é um controle diretivo.

Questão 10: Alternativa B — Físico detectivo

Sensores de movimento infravermelho e contatos de porta são controles físicos usados para identificar atividade não autorizada depois que ela ocorre. Seu propósito principal é detectar intrusões, tornando este um controle físico detectivo.